

Grand Canyon University

ITT-380 Information Assurance | College of Engineering and Technology

Liela Pressley

Across the States Information Assurance Plan

May 5, 2024

Video Presentation:

https://www.canva.com/design/DAGEbvd87sI/CgHIeuRIvZHA3GoIttUojQ/view?utm_content=DAGEbvd87sI&utm_campaign=designshare&utm_medium=link&utm_source=recording_view

Table of Contents

1. Executive Summary
2. Key Definitions
3. Introduction
4. Objectives
5. Roles & Responsibilities
6. Critical Assets, Application, and Resources
7. Risk Assessment
8. Ongoing Vulnerability Assessment
9. Risk Reduction
10. Incident Response Planning
11. Business Continuity & Recovery
12. Summary/Conclusions

Executive Summary

Across the State Bank is dedicated to providing premier banking services internationally and locally 24/7, therefore its dedication is translated to ensuring that consumer, employee and client information and information systems are secured, available and confidential. This plan is dedicated to sharing the roles and responsibilities of main leadership in relation to information assurance, the identification of key assets in our organization, and who this plan applies to. This plan identifies the cornerstone of performing risk assessments, maintaining vulnerability assessments, the importance of clear communication and tools, what is needed for incident response planning and what business continuity/recovery looks like for ASB.

Key Definitions

Consumer Information: Payment information, credit/debit card numbers, verification codes, billing/shipping addresses, email addresses, phone numbers, purchasing history, buying preferences, and shopping behavior

Privacy: the right of individuals, groups and organizations to determine for themselves when, how and what extent information about themselves is communicated to others

PII: information that can be used to distinguish or trace an individual's identity (i.e.: name, SSN, biometrics, etc.)

Risk: combination of vulnerabilities that may be exploited by threats together with the potential impact of the asset

Risk management: applications of methods that consist of policies, protocols and practices that are used to identify these risk and analyze them

Vulnerability: a flaw or weakness in a design, procedure, setting, control, etc. that may allow harm to occur to a system, activity, information if exploited.

Introduction

Across the State Bank aims to become the premier banking service provider across all business segments and provide outstanding customer centered financial service. The ASB provides services domestically and internationally 24/7 via phone, email, online chatting, online banking and mobile banking. With the wide range of services and employee interactions, this plan is meant to protect ASB information and information systems from unauthorized access, use, disclosure, disruption, modification, and destruction. All procedures that ASB adheres to are consistent with the international, federal and state security and privacy laws/standards/policies. With a risk and cost/benefit approach each system owner and department may have various strategies designed to be parallel with the regulations, risks and vulnerabilities relevant to their systems and geographical location to best secure information systems and protect privacy information.

Objectives

What are the objectives of the Across the States Bank IAP?

The objectives of this document is to establish an Information Assurance Plan that:

- Protect the Interconnection of Systems and the Privacy and Business Sensitive Information
- Provide A Foundation to Maintain Confidentiality, Integrity, Availability, Authenticity and Nonrepudiation of Information Regardless of its State
- Implement the Best Security Practices Based on the Risk and Cost/Benefit Approach

- Implement Efficient and Cost-Beneficial Practices of Security Methods
- Establish Clear Responsibilities and Accountability Across Various Roles
- Establish Clear Assessments and Continuous Monitoring to Improve Threat/Risk Awareness
- Provide Training and Awareness Guidelines to Promote Understanding of IAP

Roles & Responsibilities

The CISO is responsible for developing and maintaining CNCS's IAP and IP policies which are reviewed and updated annually to address changes and problems identified by audits, plan implementation, Federal Information Security Management act reviews, and security control assessments. The policies are reviewed to the COI, policy council for review then submitted to the CEO for approval.

Chief Executive Officer (CEO)

The CEO is responsible for ensuring that the IAP is developed and implemented while allocating resources and ensuring commitment to the plan as a whole. This role ensures that the CIO, CISO, AO and ISO are appointed.

Chief Information Officer (CIO)

The CIO is responsible for executing the overall IT program, and delegates authority to CISO for managing the Information Assurance Program. The main goals of IT management and governance focuses on ensuring that information security management processes are integrated with strategic planning, that ASB has well trained personnel to comply with IA requirements. In addition to coordinating with senior management to report annually the effectiveness of ASB's Information Assurance Plan.

Chief Information Security Officer (CISO)

The CISO carries out the COI's security and privacy responsibilities and manages the IAP. The CISO is expected to have professional qualifications (training/experience), administer the IAP objectives and functions, make maintaining IA duties a first priority, head mission and resources office to assist ASB in achieving more secure information and information systems.

Authorizing Official (AO)

The AO is appointed by the CEO and has the authority to take responsibility for operating an information system at an acceptable level of risk and responding to security incidents/privacy breaches. This position oversees the budget allocation for information systems and is responsible for the mission/business operations supported by the system and approves the system security plans, plans of action, and milestones. In addition, AOs can deny authorization to operate an information system, halt an operating system if unacceptable risks are present.

Information System Owner (ISO)

The ISO is appointed by the CEO and serves as the central point of contact during a security authorization process. ISOs are responsible for coordinating data protection requirements with IOs who have information stored and processed in the system, deciding who has access to the system and access privileges/rights, ensure that system users

Information Owner (IO)

The IO is an ASB official who has the authority to regulate, manage, and operate specific information and is responsible for establishing policies and procedures that govern generating, collecting, processing, disseminating, and disposing information. In addition IOs provide input to

ISO about security requirements and controls, retain info in alignment with the record schedule, categorize sensitivity level of info stored and processed, and coordinate with the ISO on changes.

Information System Security Officer (ISSO)

ISSO is appointed by the ISO and works closely with the ISO and ISSM to ensure that the security posture is being upheld for each information system and serves as a principal advisor for all security related issues. ISSOs must have detailed knowledge and expertise to manage security and are responsible for day to day security operations of a system such as physical/environmental protections, personnel security, incident handling, security training/awareness, compliance, monitoring, investigations of incidents and more.

Information Assurance Manager (IAM)

IAM is the primary liaison for the CISO to individual switch security and privacy responsibilities and supports information assurance activities. They are responsible for monitoring compliance with international, federal, state and all ASB policies, while providing guidance on implementing the policies. They investigate system security and privacy incidents, provide support for audits and reviews, and manage vulnerability management.

Information System Security Manager (ISSM)

The ISSM coordinates system security tasks while providing oversight responsibilities to ensure security activities are performed and serves as a liaison between ISSO and ISO.

Contracting Officer's Representative (COR)

The COR acts as the technical liaison between CO and the contractor, provides technical assistance, performs onboarding and offboarding activities for contractors assigned to contract, ensures that contracts have proper background investigations before being able to access ASB

information and systems. COR are to ensure that contractors are properly maintaining information and information systems in accordance with the IAP of ASB.

Security Assessment Team (SAT)

SAT conducts assessments of the security controls to determine the overall effectiveness of the controls which includes developing a security assessment plan for each subset of security controls and submitting that plan for approval. In addition, SATs are to conduct the assessment of security plan and provide an assessment of severity of weaknesses discovered and recommend corrective actions to address identified vulnerabilities.

Cyber Governance, Risk and Compliance Team (CGRC)

The CGRC is responsible for cyber governance and compliance for all information systems. They are to coordinate and work with Information Owners, Systems Owners and support other teams in establishing their systems categorization, finalize ATO (authorization) packages for the systems and work with the AO to issue the system's authorization to operate.

Critical Assets, Application, and Resources

The main objective of the information assurance plan is to protect the confidentiality, integrity and availability of ASB's assets throughout its life cycle.

ASB Asset Identification

1. Tangible ASB Assets

- a. data/information including but not limited to (in hard or soft copy): Databases, ASB employee PII, personnel records, proposals, contracts, statistics, ASB consumer PII, bank statements, banking information, transactions (history)
 - b. Hardware including but not limited to: computer/network equipment, tape, removable media such as USB flash drives and hard drives, etc.
 - c. People including but not limited to: staff with expertise, skill, knowledge,
 - d. Services including but not limited to: electricity, telecommunications, lighting, mobile application connections, chat connections
 - e. Software including but not limited to: application software, system software, system utilities, development tools, management desktop applications, dashboards, communication softwares, etc.
 - f. Cash, accounts, notes receivable, stocks, bonds, negotiable investment securities
2. Intangible ASB Assets
- a. Reputation, image, influence (nature of goodwill)
 - b. Intellectual property and legal rights such as trademarks, patents, copyrights, and trade secrets of ASB
 - c. Relationships including but not limited to: core depositors, mortgage/loan servicing, credit card customer, consumer/commercial, leasing consumer, etc.

Application

This plan applies to all ASB employees including, full time, part-time, temporary, contractors, interns, volunteers, and any other individual who operates and/or has access to ASB information and/or information systems.

This plan applies to systems owned by a contractor as they are to implement system security controls and are to be assessed against the same NIST criteria and standards ASB upholds.

Violation of any of the protocols or policies listed in this plan can result to loss/limitations on use of information resources and disciplinary and/or legal action.

Resources

ASB's mission prioritizes providing 24/7 service to all of their consumers and offers a wide range of services across the globe. The information assurance efforts must prioritize allocating resources to the necessary protocols and efforts to ensure that CIA security elements are being implemented to all ASB assets involved in the life cycle.

It is more cost effective to include resources earlier in the development process of ASB systems rather than add them once the systems are in an operational state. However this is not always applicable which enforces the role of the stakeholders and leadership team to communicate with system owners and management teams to determine what the biggest needs are and what implementations are working. It is better to provide cost-efficient practices to reduce critical risks while also being prepared if/when an incident occurs.

Risk Assessment

1. Background Planning- establish the strategic and risk management context at the beginning to set the precedent by establishing an aim, scope and boundary
 - a. This is where required resources are specified, risk evaluation criteria is established, and a standard threat profile can be used to provide an estimate
2. Asset Analysis- reference the list of assets provided and conduct a asset valuation

- a. Identify significant assets and analyze their values with the lens of the CIA, determine each asset's owner, its value and impact toward the organization/goals.
3. Threat Analysis- identify and examine threats to each asset within ASB within a classified and organized manner
 - a. Human vs Natural
4. Vulnerability Analysis- identify vulnerabilities for which the threat events exist that can be exploited by potential threat actors- this list should be continuously updated and added to as much as possible
5. Risk Identification- risk are to be identified as early as possible by using a structured brainstormed session from experience by the team or outside help
6. Risk Analysis- sources of the risks are reflected upon and followed by estimation of likelihood of occurrence. Determine the asset values and the probability of threats exploiting the vulnerability and its impacts.
7. Risk Treatment- Within a risk treatment plan risks will be formally identified, selected and documented and will include options such as:
 - a. Avoiding the risk altogether (not proceeding with the activity)
 - b. Reduce the likelihood of occurrence (audit/compliance, inspections, etc.)
 - c. Reduce the consequences (contingency planning, business continuity planning, etc.)
 - d. Transfer Risk (Use insurance, partnerships, etc.)
 - e. Accept Risk

Ongoing Vulnerability Assessment

Continuous vulnerability assessments are essential to ensuring that systems and information are being secured and protected. System and asset owners will have the most understanding of what vulnerabilities are high priority and relevant.

It is important to have an up to date list of vulnerabilities that are prioritized and communicated to relevant stakeholders, leadership and teams.

ASB will have scanning/automated tools to scan the systems for vulnerabilities and will have regular assessments to identify weakness.

Some tools that are to be implemented in a daily practice include:

- Intrusion detection systems
- Host intrusion detection systems
- Network intrusion detection systems
- Log management tools
- Security Information and Event Management Tools
- State Detection
- Vulnerability Scanners
 - Host-based
 - Network-based
 - Database
 - Distributed Network

Risk Reduction

Each system, department, and information branch will need to have a detailed and specified course of action as each risk has different levels of severity and relevance.

When attempting to reduce risk, the team, owner and leadership will communicate clearly and effectively what that risk is identified to be, the level of severity and impact that asset will have if effected.

To reduce risk ASB encourage teams and owners to seek guidance from CGRC teams and SAT to select from the following options:

- Implement audit and compliance programs
- Formal Reviews
- Inspection and Process Controls
- Preventative Maintenance
- Contingency Planning
- Business Continuity Planning
- Reducing Interdependent Activities

Incident Response Planning & Recovery

Incident response is the first step to recovery and needs to be managed appropriately to boost ASB into strength rather than becoming weaker. It is best to have a well developed plan so that when an incident occurs our teams, systems and information are ready and well protected and standing on a foundation to respond and recover quickly and effectively.

Start by ensuring that our IT personnel are versed on resources such as:

- Evidence management

- Criminal investigations
- Civil investigations
- Administrative investigations
- Response to security incidents
- E-discovery and intellectual property.

Phase 1- Preparation: A good incident response plan is going to start with preparation that is going to be collaborated on with the team, management and relevant players such as contractors, law enforcement, legal counsel, vendors, etc. It will contain a emergency/crisis communication plan; if an incident occurs, who are the main employees to call, how and what severity is determining this plan.

Phase 2- Detection/Identification: Once an incident occurs, there needs to be a designated individual to be the primary incident handler in the identification phase which means being aware of the situation, and being updated on the status. The incident handling team are to perform assessments on the validity of the incident and assess and record the evidence of the event that can be witnessed via firewalls, logs, intrusion detection systems, etc.

Phase 3- Containment: Once the incident is identified, ASB is to focus on mitigating and/or stopping the damage as much as possible and prevent the incident from spreading and escalating.

Phase 4-Eradication: Though the most difficult this stage is to remove malicious codes completely and safely and depending on the severity of this incident, identifying and removing multiple vulnerabilities that were exploited. If necessary, ASB will recruit specialists to assist in reverse engineering the malware.

Phase 5-Recovery: After eradicating all of the malware/exploits, ASB will work to rebuild the systems and recovery them into operation if possible (when backups and baseline configurations are established). If recovering from an alternative state they will follow a disaster recovery plan.

Phase 6-Review: After an incident, ASB is determined to become stronger and learn from them to better prepare for the future and to continue to protect their consumers and employees. There needs to be a detail, effective and accurate follow up report and a review meeting to give the incident handling team time to share and learn from this experience. This will also provide evidence of what resources need to be allocated or reallocated towards Information Assurance in ASB.

Business Continuity

Business continuity is highly prioritized at ASB has so many consumers, businesses and employees rely on the organization's services and customer service. To promote a success business continuity plan ASB ensures that:

- The business continuity program is fully supported by management and stakeholders; they see the priority and need to allocate sufficient resources to this program
- The business continuity program is taking initiatives to report levels and individual responsibilities and ensuring that all departments are aware of their roles
- At ASB, business continuity is going to run parallel to the information assurance plan/program as it is so necessary that teams work collaboratively to best provide availability and security to its services, information and information systems.

Summary/Conclusions

Across the States bank is dedicated to providing Confidentiality, Availability, Integrity, Availability, Authenticity and Nonrepudiation of Information in all forms. This information assurance is to provide a guideline and foundation for the organization to uphold this objective for their employees, systems, and consumers equally. Each responsibility, policy, plan, and assignment has a purpose and is meant to be a stepping stone to propel the organization to being stronger, and better prepared if or when an incident occurs.

References

- Adams, M., Johnson, C., Kahn, J., & King, S. (n.d.). Considerations for Allocating Resources for Information Security¹. *The MITRE Corporation*.
<https://citeseerx.ist.psu.edu/document?repid=rep1&type=pdf&doi=a7a7b14fec0a159115682cd81026f3627705eb8a>
- Chinnasamy, V. (2024, March 4). The Importance of Vulnerability Assessment: Types and Methodology. Indusface. <https://www.indusface.com/blog/explore-vulnerability-assessment-types-and-methodology/>
- FISMA A&A roles and responsibilities - NCI Security and Compliance Information - NCI Wiki*. (n.d.).
[https://wiki.nci.nih.gov/pages/viewpage.action?pageId=389089950#:~:text=The%20Information%20System%20Owner%20\(commonly,disposal%20of%20an%20information%20system.](https://wiki.nci.nih.gov/pages/viewpage.action?pageId=389089950#:~:text=The%20Information%20System%20Owner%20(commonly,disposal%20of%20an%20information%20system.)
- Reilly, R. F., Jr. (2010). Intangible asset valuation insights. *Insights*, 80–81.
https://willamette.com/insights_journal/10/winter_2010_10.pdf
- Schou, C., Hernandez, S. (2015). Information assurance handbook: Effective computer security and risk management strategies. McGraw Hill LLC.

